

Regra de Negócio: Auditoria

docs/business-rules

Ciclartech · Plataforma de Gestão de Ativos Assistivos

Auditoria

Objetivo

Manter uma trilha de segurança e conformidade LGPD de quem fez o quê no sistema — separada da Timeline operacional do ativo (que conta a história do ativo em si, não a história de acessos/alterações do sistema).

Fluxo operacional

Usuário realiza uma ação (login, criação, alteração, exclusão, acesso a dado pessoal, exportação, etc.)

↓

Sinal do Django captura o evento automaticamente

↓

Registro de auditoria é gravado (nunca editável, nunca excluível)

↓

Admin/Gestor consulta a trilha do próprio tenant;
Owner consulta a trilha cross-tenant

Regras de negócio

- Captura automática por sinais (`pre_save` / `post_save` / `post_delete`) para os apps `core` , `contas` , `ativos` , `beneficiarios` , `notificacoes` — o próprio app `auditoria` se exclui da captura, para não auditar a auditoria.
- Três ações de CRUD são gravadas automaticamente: `criacao` , `alteracao` , `exclusao` . Além disso, o catálogo de ações auditáveis cobre eventos de autenticação (`login_sucesso` , `login_falha` , `logout` , `bloqueio_tentativas` , `acesso_negado` , `senha_alterada` , `senha_reset_solicitado`) e de direitos do titular de dados (`acesso_dado_pessoal` , `exportacao_dados` , `anonimizacao` , `consentimento_registrado` , `consentimento_revogado`).
- Em `alteracao` , o registro guarda **apenas os nomes dos campos que mudaram** (ex.: "Campos alterados: cpf, telefone"), nunca os valores antes/depois — decisão proposital para não duplicar dado pessoal dentro da própria trilha de auditoria.
- O registro de auditoria é **append-only**: não pode ser alterado nem excluído depois de gravado, nem pelo próprio Owner.

- Cada registro guarda uma cópia textual da identificação do usuário (`usuario_identificacao`), preservada mesmo que o usuário seja posteriormente removido do sistema.
- IP e user-agent são capturados quando disponíveis; o IP só considera o cabeçalho `X-Forwarded-For` se houver proxies confiáveis configurados — evita que um cliente malicioso forje o próprio IP.

Validações

- Falha ao gravar um registro de auditoria nunca derruba a requisição que a originou — best-effort, com log da falha.

Permissões por perfil

Ação	Nível mínimo
Consultar auditoria do próprio tenant	Gestor ou Admin
Consultar auditoria de todos os tenants	Owner
Exportar auditoria em CSV (mesmo filtro da tela, sem paginar)	mesmo nível de quem consulta a tela

Estados possíveis

Não aplicável — cada registro é um evento pontual e imutável, não um objeto com ciclo de vida.

Casos de exceção

- Alterações feitas via `bulk_create`, `bulk_update` ou `QuerySet.update()` **não** disparam os sinais de auditoria — é uma limitação conhecida: qualquer rotina que use essas operações precisa registrar o evento manualmente, ou evitar esse padrão em dados sensíveis.

Impactos em outros módulos

- É a base para a resposta de "o que o Gestor/Funcionário fez" — pedida explicitamente como requisito de visibilidade do Admin.
- Complementa (não substitui) a Timeline do ativo (`docs/business-rules/timeline.md`): a Timeline responde "o que aconteceu com este ativo"; a Auditoria responde "quem alterou o quê no sistema, quando, e de onde".
- É a fonte de dados do **limite de taxa** (`auditoria/limitador.py`): login já tinha bloqueio por tentativa (`contas/bloqueio.py`), mas uma conta autenticada (legítima ou comprometida) não tinha nenhuma barreira contra gerar movimentação/exportação/

anonimização em volume. O limitador conta eventos já gravados aqui, nos últimos N minutos, por usuário — não é uma tabela nova, é uma consulta sobre a trilha existente. Limiares hoje: 60 movimentações de ativo / 5 min, 20 exportações / hora, 5 anonimizações / hora (todos por conta, generosos o bastante para não afetar uso humano normal de balcão). Bloqueio grava uma única linha de `ACESSO_NEGADO` por janela, não uma por tentativa recusada — mesmo motivo do bloqueio de login: quem abusa controla o volume de tentativas, logar cada uma inundaria a própria trilha que deveria detectar o abuso.